

Security+ 4.5 · Firewalls

Master CyberSec — Official CompTIA Security+ (SY0-701) Comprehensive Study Guide · **Lesson 4.5** —
Firewalls (11:31) · [Official YouTube Video ↗](#) · [Professor Messer Study Hub ↗](#)

Executive Lesson Summary: NGFW (Next-Generation Firewall) is application-aware (identifies traffic by application), user-aware, integrates threat intelligence, and performs SSL inspection. UTM (Unified Threat Management) combines multiple security functions in one appliance, suitable for small businesses. A screened subnet (DMZ) is a buffer zone between the internet and the internal network. Firewall rules define allow/deny based on port, protocol, and IP.

High-Yield Core Concepts Tested on Exam

- NGFW = stateful inspection + application awareness + user awareness + threat intelligence
- Screened subnet (DMZ) is a zone between the internet and the internal network
- UTM combines multiple security features into a single appliance
- Firewall rules specify allow/deny, port, protocol, and IP address
- SSL inspection allows the firewall to inspect encrypted traffic
- NGFW can enforce policies based on user identity

Exam Tips & Classic Scenarios

- If the question mentions 'firewall that inspects traffic at the application layer', the answer is NGFW or WAF
- Remember: NGFW is application-aware and user-aware; UTM is all-in-one for smaller environments

Typical Exam Scenario: A company deploys a modern firewall that recognizes applications and applies rules based on user identity. This is an NGFW.

Beyond the Video: Official CompTIA Exam Concepts, Protocols & Traps (Lesson 4.5 — Firewalls)

Why is this advanced coverage required for SY0-701? Video overviews provide foundational familiarity, but CompTIA tests practical engineering judgment and requires deep familiarity with the following protocols, acronyms, and operational nuances in this domain:

- **WAF:** Web Application Firewall: Layer 7 security inspection appliance/service that inspects and filters HTTP/HTTPS payloads against OWASP Top 10 exploits such as SQL Injection, XSS, and CSRF.

Classic CompTIA Traps & Question Framing:

- Avoid rote memorization: CompTIA exam prompts regularly adjust technical constraints requiring you to defend why one valid security control is the *MOST appropriate* or *FIRST step*.
- Scrutinize question qualifiers: 'without additional licensing costs' favors native OS tools; 'granular administrative command accounting' favors TACACS+ over RADIUS; 'non-repudiation' mandates asymmetric private key signing.

Practice Questions with In-Depth Solutions (10 Questions)

Detailed answer key with step-by-step technical rationale and comprehensive distractor breakdown provided below. Attempt answering independently first.

1. Which network security device operates at the application layer (Layer 7) and can inspect HTTP/HTTPS content?

- A)** Traditional stateful firewall
- B)** Web Application Firewall (WAF)
- C)** Layer 2 switch
- D)** Hub

2. Difference between IDS and IPS:

- A)** IDS detects and alerts; IPS detects and BLOCKS
- B)** They are the same thing
- C)** IDS is disk-based; IPS is network-based
- D)** IPS only logs

3. An isolated subnet that exposes public servers (web/email) while protecting the internal network is a:

- A) Voice VLAN**
- B) DMZ (screened subnet)**
- C) VPN**
- D) Intranet**

4. Corporate scenario (Firewalls): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 4.5), an analyst evaluates the following technical requirement: 'NGFW = stateful + app + user + threat intelligence'. What is the best recommendation or applicable control classification?

- A) Temporarily disable audit logs to accelerate system throughput**
- B) Replace preventive technical controls with informal terms of adherence**
- C) Implement the corresponding solution: NGFW = stateful + app + user + threat intelligence...**
- D) Allow shared access among administrators with generic credentials**

5. Corporate scenario (Firewalls): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 4.5), an analyst evaluates the following technical requirement: 'Screened subnet (DMZ): zone between the internet and the internal network'. What is the best recommendation or applicable control classification?

- A) Implement the corresponding solution: Screened subnet (DMZ): zone between the internet and the internal network...**
- B) Temporarily disable audit logs to accelerate system throughput**
- C) Replace preventive technical controls with informal terms of adherence**
- D) Allow shared access among administrators with generic credentials**

6. Corporate scenario (Firewalls): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 4.5), an analyst evaluates the following technical requirement: 'firewall that inspects traffic at the application layer'=NGFW/WAF. What is the best recommendation or applicable control classification?

- A)** Implement the corresponding solution: 'firewall that inspects traffic at the application layer'=NGFW/WAF...
- B)** Temporarily disable audit logs to accelerate system throughput
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators with generic credentials

7. Corporate scenario (Firewalls): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 4.5), an analyst evaluates the following technical requirement: "modern firewall that recognizes apps and applies rules to users'=NGFW'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Allow shared access among administrators using generic credentials
- D)** Implement the corresponding solution: 'modern firewall that recognizes apps and applies rules to users'=NGFW...

8. Corporate scenario (Firewalls): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 4.5), an analyst evaluates the following technical requirement: 'NGFW = stateful + app + user + threat intelligence'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Allow shared access among administrators with generic credentials
- D)** Implement the corresponding solution: NGFW = stateful + app + user + threat intelligence...

9. Corporate scenario (Firewalls): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 4.5), an analyst evaluates the following technical requirement: 'Screened subnet (DMZ): zone between the internet and the internal network'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to speed up system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Implement the corresponding solution: Screened subnet (DMZ): zone between the internet and the internal network...
- D)** Allow shared access among administrators with generic credentials

10. Corporate scenario (Firewalls): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 4.5), an analyst evaluates the following technical requirement: 'firewall that inspects traffic at the application layer'=NGFW/WAF'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Allow shared access among administrators with generic credentials
- D)** Implement the corresponding solution: 'firewall that inspects traffic at the application layer'=NGFW/WAF...

COMPREHENSIVE ANSWER KEY & DISTRACTOR BREAKDOWN

1) B — Web Application Firewall (WAF).

✓ **Why it's correct:** A **Web Application Firewall (WAF)** is a security device that operates at the application layer (Layer 7 of the OSI model) and is designed to inspect HTTP/HTTPS traffic, protecting web applications against attacks such as SQL injection, cross-site scripting (XSS), cross-site request forgery (CSRF), among others. It analyzes the content of requests and responses, applying rules based on signatures or anomalous behavior. In the CompTIA Security+ (SY0-701) syllabus, WAF is explicitly cited as an application-layer security control to protect web servers. Therefore, it is the exact answer to the description.

✗ **Why the others are wrong:**

- *Traditional stateful firewall:* A traditional stateful firewall operates at the network and transport layers (Layers 3 and 4). It maintains a state table of connections and allows or blocks packets based on IP addresses, ports, and connection state. However, it does not inspect application-layer content (HTTP/HTTPS) and therefore cannot detect attacks like SQL injection or XSS. To inspect HTTP/HTTPS content, a next-generation firewall (NGFW) with deep packet inspection or a WAF would be required. Thus, the traditional stateful firewall does not meet the requirement of operating at the application layer and inspecting content.
- *Layer 2 switch:* A Layer 2 switch operates at the data link layer (Layer 2) and is responsible for forwarding Ethernet frames based on MAC addresses. It lacks application-level traffic inspection capabilities, let alone HTTP/HTTPS content. Its function is to connect devices within the same local network, segmenting collision domains. It is not a Layer 7 security device and cannot inspect content. Therefore, it is incorrect.
- *Hub:* A hub is a physical layer (Layer 1) device that simply repeats electrical signals to all ports, without any forwarding intelligence or inspection. It does not operate at higher layers and offers no security functionality, much less HTTP/HTTPS content inspection. Hubs are obsolete and replaced by switches. Hence, it does not apply to the context of application-layer security.

2) A — IDS detects and alerts; IPS detects and BLOCKS.

✓ **Why it's correct:** The fundamental difference between IDS (Intrusion Detection System) and IPS (Intrusion Prevention System) lies in the action taken after detecting an intrusion. IDS monitors network traffic or system activities for malicious patterns and, upon detection, generates alerts for administrators to investigate. It is passive and does not interfere with data flow. IPS, on the other hand, is active: besides detecting, it blocks or prevents malicious activity in real time, dropping packets, resetting connections, or applying other countermeasures. This distinction is tested in the Security+ (SY0-701) Security Architecture and Design domain, objective 3.2, which covers network security technologies.

✗ **Why the others are wrong:**

- *They are the same thing:* IDS and IPS are distinct technologies with different functions and network placements. IDS is a passive detection system, typically connected to a SPAN port or TAP, analyzing copies of traffic. IPS is an active prevention system, installed inline with the data flow, capable of blocking attacks. Claiming they are the same ignores their operational differences, network impact, and incident response, and contradicts established information security definitions.
- *IDS is disk-based; IPS is network-based:* This statement is incorrect because both can operate on network or host. There are HIDS (Host-based IDS) and HIPS (Host-based IPS), which monitor activities on a single device, including system calls and file integrity. Similarly, NIDS (Network-based IDS) and NIPS (Network-based IPS) analyze network traffic. The distinction is not between

disk and network, but between passive detection and active prevention. The alternative confuses monitoring scope with response mechanism.

- *IPS only logs*: This description applies more to an IDS, which typically logs events and emits alerts. IPS is not limited to logging; its primary function is to actively block intrusion attempts. Although many IPS also generate logs for auditing, its defining characteristic is the ability to prevent attacks in real time, taking actions such as dropping malicious packets or terminating sessions. Reducing IPS to a mere log recorder underestimates its critical active protection function.

3) B — DMZ (screened subnet).

✓ **Why it's correct:** The correct answer is 'DMZ (screened subnet)'. A DMZ (Demilitarized Zone), also called a screened subnet, is an isolated network segment that sits between the trusted internal network and the untrusted external network (such as the Internet). It hosts public-facing servers, such as web, email, DNS, and FTP, which need to be accessible externally. The goal is that if one of these servers is compromised, the attacker does not have direct access to the internal network, because firewalls control traffic between the DMZ and the internal network. CompTIA Security+ SY0-701, in the Architecture and Design domain (2.2), describes the DMZ as a security zone for exposing public services in a controlled manner. The question describes exactly this function: an isolated subnet that exposes public servers while protecting the internal network.

✗ **Why the others are wrong:**

- *Voice VLAN*: A voice VLAN is a virtual local area network dedicated to VoIP (Voice over IP) traffic, separating it from data to ensure quality of service (QoS) and security. It is not designed to expose public servers to the Internet; on the contrary, it isolates voice traffic. It does not provide the isolation between internal and external networks that a DMZ provides. Therefore, it does not meet the requirement of protecting the internal network while exposing public services.
- *VPN*: A VPN (Virtual Private Network) is a technology that creates an encrypted tunnel to transmit data securely over untrusted networks, enabling remote access or branch interconnection. Although it improves communication security, it is not an isolated subnet for hosting public servers. A VPN can be used to access the DMZ, but it does not replace the DMZ. The question asks for a network zone that exposes public servers, which is not the primary function of a VPN.
- *Intranet*: An intranet is a private internal network that uses Internet technologies (such as HTTP, FTP) to share information within an organization. It is accessible only to authorized users and is not exposed to the external public. Therefore, it is not used to host public servers that need to be accessed from the Internet. The intranet is the opposite of a DMZ in this respect: it is internal and restricted, not a controlled exposure zone.

4) C — Implement the corresponding solution: NGFW = stateful + app + user + threat intelligence....

✓ **Why it's correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 4.5 (Firewalls): NGFW = stateful + app + user + threat intelligence. A Next-Generation Firewall (NGFW) combines traditional stateful inspection with deep packet inspection, application awareness, user identity integration, and threat intelligence feeds. It can enforce policies based on applications, users, and content, and can detect and block advanced threats. This makes it a critical component in modern network security.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput*: Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to incident detection and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence*: Informal terms are administrative controls that rely solely on user conduct and do not block automated attacks,

injections, or malware at runtime.

- *Allow shared access among administrators with generic credentials:* Destroys individual accountability and non-repudiation. It makes it impossible to prove who performed critical changes or malicious commands.

5) A — Implement the corresponding solution: Screened subnet (DMZ): zone between the internet and the internal network....

✓ **Why it's correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 4.5 (Firewalls): Screened subnet (DMZ): zone between the internet and the internal network. A screened subnet, also known as a DMZ, is a network segment that acts as a buffer between the untrusted internet and the trusted internal network. It hosts public-facing services (e.g., web servers, email servers) and is protected by firewalls, allowing controlled access while minimizing the attack surface on the internal network.

✗ Why the others are wrong:

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls that rely solely on user conduct and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators with generic credentials:* Destroys individual accountability and non-repudiation. It makes it impossible to prove who performed critical changes or malicious commands.

6) A — Implement the corresponding solution: 'firewall that inspects traffic at the application layer'=NGFW/WAF....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 4.5 (Firewalls): 'firewall that inspects traffic at the application layer'=NGFW/WAF. Next-Generation Firewalls (NGFW) and Web Application Firewalls (WAF) perform deep packet inspection at the application layer, enabling advanced threat detection and application-aware filtering.

✗ Why the others are wrong:

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to incident detection and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators with generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

7) D — Implement the corresponding solution: 'modern firewall that recognizes apps and applies rules to users'=NGFW....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 4.5 (Firewalls): 'modern firewall that recognizes apps and applies rules to users'=NGFW.

✗ Why the others are wrong:

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks

compliance standards (PCI DSS, ISO 27001).

- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user behavior, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators using generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

8) D — Implement the corresponding solution: NGFW = stateful + app + user + threat intelligence....

✓ **Why it's correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 4.5 (Firewalls): NGFW = stateful + app + user + threat intelligence.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators with generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

9) C — Implement the corresponding solution: Screened subnet (DMZ): zone between the internet and the internal network....

✓ **Why it's correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 4.5 (Firewalls): Screened subnet (DMZ): zone between the internet and the internal network.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to speed up system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators with generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who made critical changes or malicious commands.

10) D — Implement the corresponding solution: 'firewall that inspects traffic at the application layer'=NGFW/WAF....

✓ **Why it's correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 4.5 (Firewalls): 'firewall that inspects traffic at the application layer'=NGFW/WAF. Next-Generation Firewalls (NGFW) and Web Application Firewalls (WAF) operate at the application layer (Layer 7) to inspect and filter traffic based on application-specific content.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).

- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators with generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.